Cyber Threat Intelligence Report

Generated: 2026-10-18 18:32

Source document: aa23-352a-stopransomware-play-ransomware_2_revised.pdf (18 pages)

Subject: Analyze the uploaded threat report 'aa23-352a-stopransomware-play-ransomware_2_revised.pdf'.

Overall risk: High (8.5/10), likelihood Likely, P2 - High

1. Executive Summary

Threat type: Ransomware (double-extortion). Malware: Play ransomware. Attack summary: The Play ransomware group employs a double-extortion model, first exfiltrating data and then encrypting files. Initial access is achieved through compromised valid accounts, exploitation of public-facing vulnerabilities in FortiOS (CVE-2018-13379, CVE-2020-12812), Microsoft Exchange (ProxyNotShell CVE-2022-41040, CVE-2022-41082), and the RMM tool SimpleHelp (CVE-2024-57727), as well as remote services such as RDP and VPN. After gaining foothold, actors enumerate the network with AdFind, Grixba, and other tools, disable endpoint protection with GMER, IOBit, PowerTool, and PowerShell scripts, and move laterally using Cobalt Strike, SystemBC, PsExec, Mimikatz, WinPEAS, and Group Policy Objects. The ransomware binary is recompiled for each attack, producing unique hashes, and encrypts files with a .PLAY extension, leaving a ransom note in C:/Users/Public/Music/. Victims are instructed to contact the attackers via a unique @gmx.de or @web.de email and pay in cryptocurrency, with threats to publish exfiltrated data on a Tor leak site. CVEs referenced: CVE-2018-13379, CVE-2020-12812, CVE-2022-41040, CVE-2022-41082, CVE-2024-57727. MITRE techniques: T1190 Exploit Public-Facing Application, T1059.001 PowerShell, T1027 Obfuscated Files or Information, T1078 Valid Accounts, T1562.001 Impair Defenses: Disable or Modify Tools, T1003 OS Credential Dumping, T1486 Data Encrypted for Impact. Risk: High (8.5/10), likelihood Likely, priority P2 - High. Business impact: Data confidentiality breach; Operational downtime. Response urgency: Act within 24 hours. Top immediate actions: Isolate all compromised hosts (Windows servers, FortiOS devices, Exchange servers, ESXi hosts) from the network to stop lateral movement. - Play ransomware uses valid accounts for lateral movement; isolation prevents further spread. (T1078); Terminate malicious processes and delete identified ransomware binaries (e.g., SVCHost.dll backdoor, Gt_net.exe, HRsword.exe). - Unique, recompiled binaries evade AV; removing them stops execution. (T1027); Block outbound C2 traffic and disable any active Cobalt Strike/SystemBC sessions. - Cutting C2 prevents further commands and data exfiltration. (T1059.001).

2. Threat Overview

Threat type: Ransomware (double-extortion)

Malware: Play ransomware

Attack summary

The Play ransomware group employs a double-extortion model, first exfiltrating data and then encrypting files. Initial access is achieved through compromised valid accounts, exploitation of public-facing vulnerabilities in FortiOS (CVE-2018-13379, CVE-2020-12812), Microsoft Exchange (ProxyNotShell CVE-2022-41040, CVE-2022-41082), and the RMM tool SimpleHelp (CVE-2024-57727), as well as remote services such as RDP and VPN. After gaining foothold, actors enumerate the network with AdFind, Grixba, and other tools, disable endpoint protection with GMER, IOBit, PowerTool, and PowerShell scripts, and move laterally using Cobalt Strike, SystemBC, PsExec, Mimikatz, WinPEAS, and Group Policy Objects. The ransomware binary is recompiled for each attack, producing unique hashes, and encrypts files with a .PLAY extension, leaving a ransom note in C:/Users/Public/Music/. Victims are instructed to contact the attackers via a unique @gmx.de or @web.de email and pay in cryptocurrency, with threats to publish exfiltrated data on a Tor leak site.

Indicators of compromise

• 47B7B2DD88959CD7224A5542AE8D5BCE928BFC986BF0D0321532A7515C244A1E (SVCHost.dll backdoor) [not found in the source document]

• 1409E010675BF4A40DB0A845B60DB3AAE5B302834E80ADEEC884AEBC55ECCBF7 (Grixba Gt_net.exe) [not found in the source document]

• 0E408AED1ACF902A9F97ABF71CF0DD354024109C5D52A79054C421BE35D93549 (HRsword.exe) [not found in the source document]

Affected systems

• FortiOS devices

• Microsoft Exchange servers

• SimpleHelp RMM tool

• VMware ESXi hosts

• Windows servers

Indicators extracted from the document

• IP addresses: 1.1.3.0

• Domains: www.security.com, www.trendmicro.com, www.sentinelone.com

• URLs: https://www.security.com/threat-intelligence/play-ransomware-volume-shadow-copy, https://www.trendmicro.com/vinfo/us/security/news/ransomware-spotlight/ransomware-spotlight-play, https://www.sentinelone.com/labs/crimeware-trends-ransomware-developers-turn-to-intermittent-encryption-to-evade-detection/

• Email addresses: Report@cisa.gov

• SHA-1: 3d86555acaa19aeddb5896071d1e3711b062edbe

• Files mentioned: SVCHost.dll, Gt_net.exe, PSexesvc.exe, HRsword.exe, Usysdiag.exe, fThe9C.exe, Hi.exe

Found by pattern matching, so each one appears in the source text. Reference sites and internal addresses are excluded.

CVEs referenced

• CVE-2018-13379

• CVE-2020-12812

• CVE-2022-41040

• CVE-2022-41082

• CVE-2024-57727

3. MITRE ATT&CK Mapping

Attack flow: Initial Access -> Execution -> Defense Evasion -> Credential Access -> Impact

ID	Technique	Tactic	Confidence
T1190	Exploit Public-Facing Application	Initial Access	0.95
T1059.001	PowerShell	Execution	0.95
T1027	Obfuscated Files or Information	Defense Evasion	0.95
T1078	Valid Accounts	Defense Evasion	0.95
T1562.001	Impair Defenses: Disable or Modify Tools	Defense Evasion	0.95
T1003	OS Credential Dumping	Credential Access	0.95
T1486	Data Encrypted for Impact	Impact	0.95

4. Risk Assessment

Severity: High (8.5/10)

Likelihood: Likely

Priority: P2 - High

Business impact

• Data confidentiality breach

• Operational downtime

Affected assets

• FortiOS devices

• Microsoft Exchange servers

• Windows servers

• VMware ESXi hosts

Justification

Play ransomware employs a double-extortion model that encrypts data and threatens public release, causing loss of confidential information and halting services; the group exploits widely-known vulnerabilities and has affected ~900 entities, making recurrence likely and business impact severe.

5. Mitigation Plan

Response urgency: Act within 24 hours.

Immediate actions

• Isolate all compromised hosts (Windows servers, FortiOS devices, Exchange servers, ESXi hosts) from the network to stop lateral movement. - Play ransomware uses valid accounts for lateral movement; isolation prevents further spread. (T1078)

• Terminate malicious processes and delete identified ransomware binaries (e.g., SVCHost.dll backdoor, Gt_net.exe, HRsword.exe). - Unique, recompiled binaries evade AV; removing them stops execution. (T1027)

• Block outbound C2 traffic and disable any active Cobalt Strike/SystemBC sessions. - Cutting C2 prevents further commands and data exfiltration. (T1059.001)

• Stop the encryption process by killing the ransomware executable and removing scheduled tasks that launch it. - Halting encryption limits data loss (Data Encrypted for Impact). (T1486)

• Reset passwords and revoke tokens for any accounts that may have been compromised. - Valid accounts were abused for initial access; credential reset removes attacker persistence. (T1078)

Prevention

• Apply all available patches for FortiOS, Microsoft Exchange, SimpleHelp RMM, and VMware ESXi within 24?hours. - Exploitation of these public-facing vulnerabilities is the primary initial-access vector. (T1190)

• Enforce multi-factor authentication (MFA) for all privileged and remote accounts. - MFA mitigates abuse of stolen or purchased valid credentials. (T1078)

• Segment networks to isolate critical systems (e.g., Exchange, ESXi) from general user zones. - Network segmentation limits attacker movement after initial compromise. (T1190)

• Disable unnecessary external services such as RDP and VPN for accounts that do not require them. - External-facing services are used for initial access. (T1190)

• Deploy application isolation or sandboxing for web-exposed services. - Isolation reduces the impact of a successful exploit. (T1190)

Detection

• Enable PowerShell Script Block Logging (Event ID?4104) and alert on encoded or obfuscated commands. - PowerShell is used for remote code execution and C2. (T1059.001)

• Monitor for service stop or configuration changes to Windows Defender, GMER, IOBit, or other security tools. - Attackers disable endpoint protection to evade detection. (T1562.001)

• Alert on mass file renaming to the .PLAY extension or creation of ransom notes in C:/Users/Public/Music/ReadMe.txt. - These are indicators of the encryption phase. (T1486)

• Log and alert on login attempts from unusual locations, times, or using dormant privileged accounts. - Valid-account abuse is a key initial-access method. (T1078)

• Scan newly created binaries for high entropy or packing characteristics. - Recompiled ransomware binaries are obfuscated to avoid AV detection. (T1027)

Recovery

• Restore encrypted data from verified, offline backups after confirming the environment is clean. - Backups provide a reliable path to recover without paying ransom.

• Conduct a full credential reset for all domain and service accounts. - Credential dumping tools like Mimikatz may have harvested passwords.

• Perform a post-incident threat-hunt to locate any remaining malicious artifacts or persistence mechanisms. - Ensures complete eradication before returning to production.

• Document the incident timeline, IOCs, and lessons learned; update incident response playbooks. - Improves future detection and response capabilities.

ATT&CK mitigation reference

Technique	ATT&CK mitigations	Detection guidance
T1190 Exploit Public-Facing Application	M1048 Application Isolation and Sandboxing, M1050 Exploit Protection, M1030 Network Segmentation, M1026 Privileged Account Management, M1051 Update Software, M1016 Vulnerability Scanning	Monitor web and application logs and WAF alerts for exploitation attempts and unexpected child processes of internet-facing services.
T1059.001 PowerShell	M1049 Antivirus/Antimalware, M1045 Code Signing, M1042 Disable or Remove Feature or Program, M1038 Execution Prevention, M1026 Privileged Account Management, M1021 Restrict Web-Based Content	Enable PowerShell Script Block Logging (Event ID 4104) and alert on encoded commands or download cradles.
T1027 Obfuscated Files or Information	M1049 Antivirus/Antimalware, M1040 Behavior Prevention on Endpoint	Flag high-entropy or encoded scripts and packed binaries; scan decoded content with AV/EDR.
T1078 Valid Accounts	M1032 Multi-factor Authentication, M1027 Password Policies, M1026 Privileged Account Management, M1018 User Account Management, M1017 User Training	Alert on logins from unusual locations or times and on use of dormant or privileged accounts.
T1562.001 Impair Defenses: Disable or Modify Tools	M1022 Restrict File and Directory Permissions, M1024 Restrict Registry Permissions, M1018 User Account Management, M1038 Execution Prevention, M1047 Audit	Alert on security-tool service stops, Defender configuration changes and tamper events.
T1003 OS Credential Dumping	M1026 Privileged Account Management, M1027 Password Policies, M1015 Active Directory Configuration, M1040 Behavior Prevention on Endpoint	Monitor access to credential stores and use of credential-dumping tools.

Technique	ATT&CK mitigations	Detection guidance
T1486 Data Encrypted for Impact	M1053 Data Backup, M1040 Behavior Prevention on Endpoint	Alert on mass file modification or renaming, new file extensions and ransom notes; deploy canary files.

6. Evidence and Sources

Cited by the agents

• aa23-352a-stopransomware-play-ransomware_2_revised.pdf, page 2 - double-extortion model and ~900 reported victims

• aa23-352a-stopransomware-play-ransomware_2_revised.pdf, page 3 - initial access via FortiOS, Exchange, SimpleHelp vulnerabilities and valid accounts

• aa23-352a-stopransomware-play-ransomware_2_revised.pdf, page 4 - file encryption with .PLAY extension and ransom note placement

• aa23-352a-stopransomware-play-ransomware_2_revised.pdf, page 6 - ESXi variant powers off VMs, causing operational downtime

• aa23-352a-stopransomware-play-ransomware_2_revised.pdf, page 17 - list of IOCs for detection

Other retrieved passages

• aa23-352a-stopransomware-play-ransomware_2_revised.pdf, page 1

• 260818.pdf, page 1

• 260818.pdf, page 22

• 260818.pdf, page 21

7. Limitations and Assumptions

• Financial loss per incident is comparable to the industry average of $3.7?million despite no specific figure in the report

• Disabling RDP/VPN external access will not impact legitimate remote work requirements.

• All critical systems have recent, offline backups available for restoration.

• Network segmentation can be implemented without major architectural changes within 24?hours.

• Long report: 10 of 49 text chunks were selected as evidence to fit model limits.

• The Threat Analyzer listed indicators that were not found in the source document and should be treated as unverified: 0e408aed1acf902a9f97abf71cf0dd354024109c5d52a79054c421be35d93549, 1409e010675bf4a40db0a845b60db3aae5b302834e80adeec884aebc55eccbf7, 47b7b2dd88959cd7224a5542ae8d5bce928bfc986bf0d0321532a7515c244a1e.

• This report was generated automatically. Findings should be reviewed by a security analyst before action is taken.

Appendix A: Analysis Plan

```
THREAT TYPE:
Ransomware

INFORMATION NEEDED:
- Specific ransomware variants and threat actors referenced in the advisory
- Tactics, techniques, and procedures (TTPs) and indicators of compromise (IOCs) described
- Recommended mitigation and detection measures for the identified ransomware

AGENTS TO ACTIVATE:
1. Threat Analyzer — to extract and characterize the ransomware threat details from the report
2. MITRE Mapper — to map the identified TTPs to ATT&CK techniques
```

```
3. Risk Assessment — to evaluate the severity, impact, and likelihood of the ransomware threat
4. Mitigation — to compile defensive measures, detection methods, and prevention strategies

RETRIEVAL PLAN:

STEP 1:
Agent: Threat Analyzer
Retrieve: Ransomware variant names, threat actor identifiers, TTPs, and IOCs mentioned in the advisory
Search query: "ransomware variants, threat actors, TTPs, IOCs in #StopRansomware advisory"
Purpose: Identify the core threat characteristics needed for mapping, risk assessment, and mitigation

STEP 2:
Agent: MITRE Mapper
Retrieve: ATT&CK technique IDs and descriptions corresponding to the TTPs identified by Threat Analyzer
Search query: "ATT&CK mapping for ransomware TTPs"
Purpose: Provide a structured framework for understanding attacker behavior and informing risk and
mitigation planning

STEP 3:
Agent: Risk Assessment
Retrieve: Risk assessment guidelines for ransomware, impact metrics, likelihood models, and affected asset
categories
Search query: "ransomware risk assessment framework, impact, likelihood"
Purpose: Quantify the overall risk posed by the identified ransomware threat

STEP 4:
Agent: Mitigation
Retrieve: Best-practice defensive controls, detection indicators, prevention strategies, and response
recommendations for ransomware
Search query: "ransomware mitigation best practices, detection, prevention"
Purpose: Generate actionable recommendations to protect against the identified threat

DEPENDENCIES:
- MITRE Mapper depends on the output of Threat Analyzer
- Risk Assessment depends on the output of Threat Analyzer
- Mitigation depends on the output of Threat Analyzer
- (Optional) Risk Assessment may also benefit from the ATT&CK mapping provided by MITRE Mapper for a more
nuanced risk profile
```

Appendix B: Agent Execution Status

Agent	Status
MITRE Mapper	success
Risk Assessment	success
Mitigation	success